Al al-Bayt University - Prince Al Hussein bin Abdullah II Faculty of Information Technology

Course Information and Database Security (906313)
First Semester 2026/2027 - Final Semester Project

SecARS

Secure Academic Records System

Group Work Plan and Release Plan

Responsibilities, schedule, Git workflow, risks and definition of done

Group members
Abdullah Ibrahim Hassan
Abdulrahman Al-Otaibi

Milestone M1 - Analysis & Design | Due Friday 06/11/2026
Version 1.0 | November 2026
Group name: SecARS

1. Group and responsibilities

The group has two members: Abdullah Ibrahim Hassan and Abdulrahman Al-Otaibi. Responsibilities below are split by area so each member owns a clear part of the system, and each deliverable is reviewed by the other member. Because the final discussion asks every member to explain any part of the system and the test evidence, every area also has a secondary owner who must be able to explain and demonstrate it.

Member	Primary role	Owns (primary)	Secondary (reviewer / backup)
Abdullah Ibrahim Hassan	Database and security lead (A)	Requirements and use cases, ERD and data dictionary, Oracle schema and constraints, seed script, ARS_API and ARS_CTX packages, users/roles/privileges, VPD, auditing (trigger, Unified Audit, FGA), TDE/TCPS, Data Pump backup/restore and masking, database tests (T3, T9-T12b), Git repository setup, final report database chapters	Backend integration with ARS_API; reviews Architecture/DFD and STRIDE; hardening checklist
Abdulrahman Al-Otaibi	Backend, frontend and application-security lead (B)	Architecture diagram, DFD and STRIDE threat model, Spring Boot REST API, Spring Security (BCrypt/Argon2, session, CSRF, CORS, lockout), React screens for the four roles, RBAC and IDOR protection, error handling, SQL-injection LAB (attack, fix, sqlmap), secrets handling, port scan and environment hardening, application tests (T1, T2, T4-T8, T13), evidence folder, final report application chapters	DB least-privilege review; VPD tests; reviews ERD and requirements

Group size: the specification sets three students per group, and any exception requires the instructor's approval. This two-member plan must be confirmed with the instructor before M1 is submitted. Member names are listed as written on the cover; roles can be swapped at the first group meeting, but the swap must be recorded in the Git history of this plan (docs/M1/).

1.1 Responsibilities per M1 deliverable

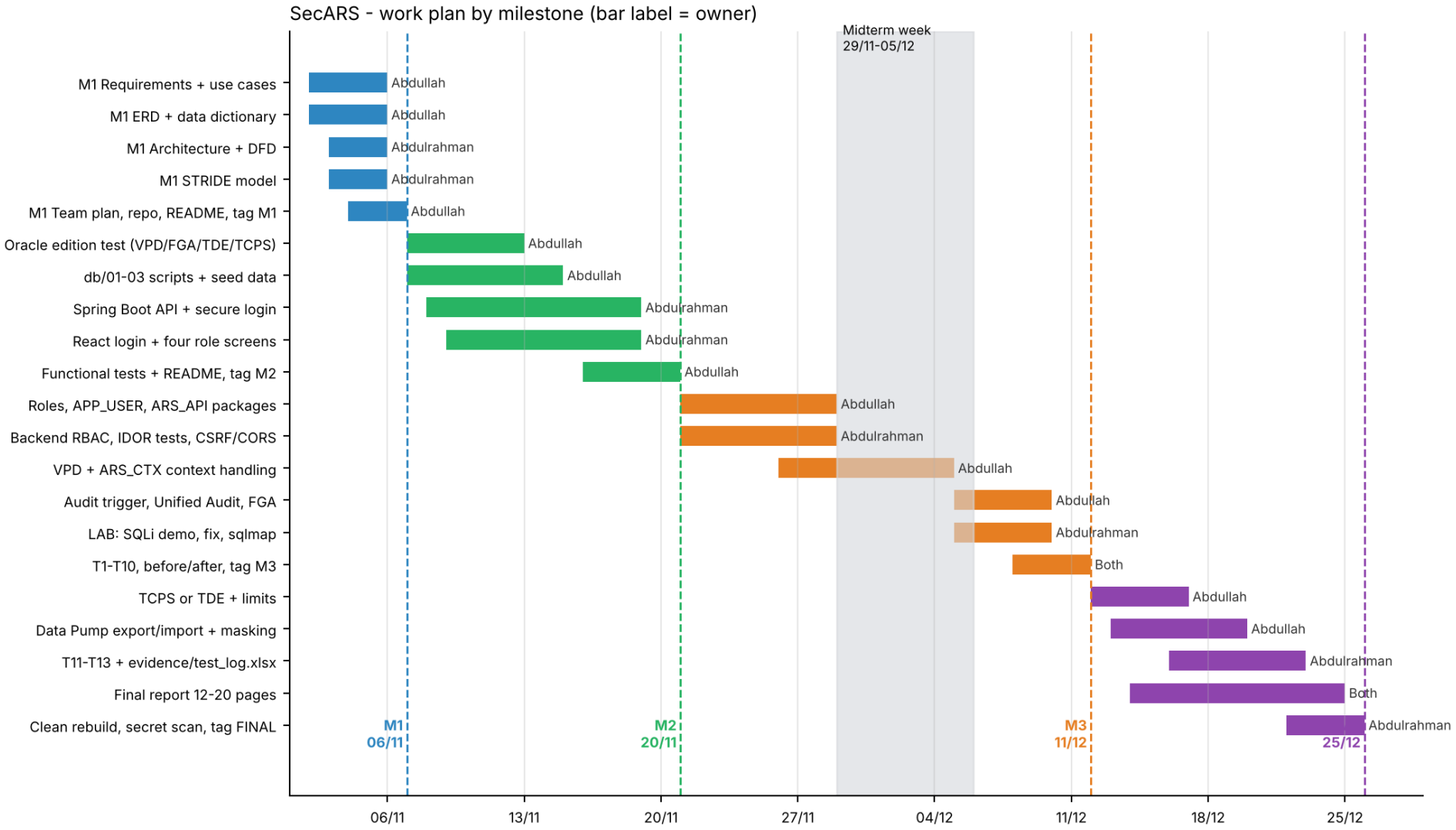
Deliverable	Author (primary)	Reviewer	Due
M1_Requirements.pdf	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi	05/11/2026
M1_ERD.pdf	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi	05/11/2026
M1_Architecture_DFD.pdf	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan	05/11/2026
M1_STRIDE.xlsx	Abdulrahman Al-Otaibi with Abdullah Ibrahim Hassan	Abdullah Ibrahim Hassan	05/11/2026
M1_TeamPlan.pdf, repository, README, tag M1	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi	06/11/2026

2. Milestones and schedule

Milestone	Due	Marks	Main content
M1 - Analysis & Design	Fri 06/11/2026	4	Requirements, ERD, architecture/DFD, STRIDE, team plan, initial repository
M2 - System Development	Fri 20/11/2026	6	Database from scratch + seed data, Spring Boot + React, secure login and sessions, functional tests
M3 - Security Implementation	Fri 11/12/2026	11	RBAC, least privilege, VPD, SQLi LAB and fix, change log, Unified Auditing/FGA, hardening, tests T1-T10
M4 - Final Assessment & Delivery	Fri 25/12/2026	9	TCPS or TDE, backup/restore, masking, tests T1-T13, final report, FINAL tag

Other dates: midterm exam week 29/11-05/12/2026 (no milestone due); group discussion in Week 14, 10-14/01/2027, on the version tagged FINAL, with no code changes after 25/12/2026. The 25/12/2026 deadline is not extended.

2.1 Gantt chart



The M3 work is front-loaded before the midterm week (roles and ARS_API), then resumes on 05/12 so that the heaviest milestone (11 marks) is not squeezed into the last days.

3. Task plan with owners

Task	Milestone	Start	End	Owner	Reviewer
M1 Requirements + use cases	M1	02/11	05/11	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
M1 ERD + data dictionary	M1	02/11	05/11	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
M1 Architecture + DFD	M1	03/11	05/11	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan
M1 STRIDE model	M1	03/11	05/11	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan
M1 Team plan, repo, README, tag M1	M1	04/11	06/11	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
Oracle edition test (VPD/FGA/TDE/TCPS)	M2	07/11	12/11	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
db/01-03 scripts + seed data	M2	07/11	14/11	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
Spring Boot API + secure login	M2	08/11	18/11	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan
React login + four role screens	M2	09/11	18/11	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan
Functional tests + README, tag M2	M2	16/11	20/11	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
Roles, APP_USER, ARS_API packages	M3	21/11	28/11	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
Backend RBAC, IDOR tests, CSRF/CORS	M3	21/11	28/11	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan
VPD + ARS_CTX context handling	M3	26/11	04/12	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
Audit trigger, Unified Audit, FGA	M3	05/12	09/12	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
LAB: SQLi demo, fix, sqlmap	M3	05/12	09/12	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan
T1-T10, before/after, tag M3	M3	08/12	11/12	Both	Each other
TCPS or TDE + limits	M4	12/12	16/12	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
Data Pump export/import + masking	M4	13/12	19/12	Abdullah Ibrahim Hassan	Abdulrahman Al-Otaibi
T11-T13 + evidence/test_log.xlsx	M4	16/12	22/12	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan
Final report 12-20 pages	M4	14/12	24/12	Both	Each other
Clean rebuild, secret scan, tag FINAL	M4	22/12	25/12	Abdulrahman Al-Otaibi	Abdullah Ibrahim Hassan

4. Git workflow and release plan

4.1 Repository

- Private GitHub repository named secars (or documented local Git with the instructor's approval). Both members have write access; the instructor is added as reader before M1 is submitted.
- Structure follows the mandatory layout: backend/, frontend/, db/ (db/security, db/recovery), lab/, docs/ (M1-M4), evidence/, contribution/, README.md, .env.example.
- Never committed: .env, wallet files, keys, admin passwords, database files, real data. .gitignore blocks them; a secret scan runs before every tag.

4.2 Branches and commits

- main always holds the last tagged or reviewable state. Work happens in short-lived branches feature/<area>-<topic> (for example feature/db-vpd, feature/api-login) and is merged by pull request reviewed by the secondary owner.

- Commit messages: <type>(<area>): <what>, with types feat, fix, test, docs, chore and areas db, api, ui, lab, docs. Every member commits their own work, because commit history is the evidence of each member's contribution.
- Security-relevant changes (privileges, VPD, audit, secrets) always need a reviewer other than the author.

4.3 Tags and releases

Tag	Date	Must contain	Gate before tagging
M1	06/11/2026	docs/M1/ (5 files), README with project overview and release plan, .env.example, empty folder structure	All five files open correctly; ERD, DFD and STRIDE names match; threat count >= 6
M2	20/11/2026	db/01_admin_setup.sql, 02_schema.sql, 03_seed.sql, backend/, frontend/, M2_FunctionalTests.pdf, README run steps	Fresh clone runs end to end against real Oracle; four role accounts log in
M3	11/12/2026	db/security/*.sql, lab/, M3_AccessMatrix.pdf, M3_SecurityTests.xlsx, M3_BeforeAfter.pdf, evidence	T1-T10 executed with request/SQL + result + log record; M2 defects fixed
FINAL	25/12/2026	Everything, db/recovery/*, evidence/test_log.xlsx, M4_FinalReport.pdf, contribution/individual_contributions.pdf	Clean-machine rebuild passed; secrets removed; T1-T13 PASS/FAIL table complete

Tags are annotated (git tag -a M1 -m ...) and pushed, so the timestamp is part of the submission. Defects found in an earlier milestone are fixed and submitted with the next milestone; the group recovers up to 50% of the marks lost once the fix is verified. Late submission costs 10% of the milestone marks per day for up to three days.

5. Working agreements and definition of done

- Group meeting at least twice a week (30 minutes) plus a short written status in the repository (contribution/weekly_log.md). Decisions that change a design document are recorded as a commit to docs/.
- Definition of done for every task: code or script in Git, reviewed by the secondary owner, documented in the README, and covered by a test or evidence entry with test ID, date, tester, steps, expected, actual and PASS/FAIL.
- Evidence is collected while working, not at the end: query or HTTP request, result, and log line, each linked to a test ID (screenshots alone are not accepted).
- All data is fictional. Attacks and scans run only against the LAB schema on localhost.
- No member works on the interface only: every member must be able to explain the architecture, the privilege model and the test evidence for the individual discussion.

6. Risks and mitigations

Risk	Impact	Mitigation
Oracle Free 26ai lacks or restricts VPD, FGA, TDE or TCPS in practice	M3/M4 controls cannot be shown	Run a compatibility test in the first week of M2 (07-12/11); report any limitation with proof to the instructor before M3 and request an approved equivalent
Oracle Free resource limits (2 CPUs, 2 GB RAM) and 16 GB laptops	Slow runs, failing demos	Container with limited memory, close other apps, use faculty lab machines as fallback; keep seed volume at the required minimum
Midterm week overlaps M3	M3 (11 marks) rushed	Front-load roles and ARS_API before 28/11; keep midterm week for small tasks; start LAB on 05/12
One member unavailable or the work concentrates on one person	Bottleneck; weak discussion marks	Secondary owner for every area; reviews by pull request; weekly log of who did what
Secret or real data committed by mistake	Integrity and security violation	.gitignore, .env.example, pre-tag secret scan, fictional data only
Trust-model limit of the application context is misunderstood	Wrong claims in the report	Document the limit in the architecture document and the final report; test and report what it does and does not protect
Late submission	10% per day deducted	Internal deadline one day before each milestone; tag candidate created on that day and fixed only for defects